"Les outils de détection , supervision et traitement des évènements de sécurité".

Deux grands domaines de la supervision et la détection des incidents.

- Le "**N**etwork **S**ecurity **M**onitoring"** est une discipline mêlant les aspects instrumentation réseau (collecte de trafic) et détection d'intrusions, essentiellement via des NIDS (**N**etwork **I**ntrusion **D**etection **S**ystems).
- Le "**H**ost **I**ntrusion **D**etection **System** est orienté "machine" et s'appuie sur les traces (logs) de ces dernières.

Définitions

- "**Threat Hunting**" ou chasse aux cyber-menaces est une activité de défense active. Il s'agit de détecter des "**A**dvanced **P**ersistent **T**hreats" ou menaces sophistiquées et persistantes dans la durée.
- "**Network FORENSICS**": cette activité désigne l'étude postmortem des traces réseaux après un incident de sécurité.
- **Détection d'intrusion**: il s'agit en temps réel de détecter et identifier des attaques déjà connues ou des anomalies.

Deux modes de détection:

- Par **scénario**: il s'agit de reconnaître la signature d'une attaque en recherchant des chaînes de caractères dans les flux des données transitant sur le réseau. On peut choisir de "reconnaître et/ou de bloquer" (**I**ntrusion **D**etection **S**ystem versus **I**ntrusion **P**revention **S**ystem).
- Par **comportement**: Il s'agit de détecter des changements dans le trafic (par exemple par analyse en composantes principales ou à l'aide des outils de type "machine learning").

Les sources de détection

- Sniffing & PCAP & Netflow (Utilisation de TAP).
- Table CAM d'un switch.
- Table de routage.
- Logs DHCP, DNS et service réseaux...
- Logs systèmes (EVT, Rsyslog).
- Log IPS/IDS.
- Logs des firewall.
- Logs des proxy.
- Logs applicatifs.

Les outils historiques de "*threat hunting*"

Sniffers: **Wireshark, tcpdump**

Collecteurs & aggrégateurs NetFlow: **nfsen, nfpcap, argus** 😄

Définition des IDS et IPS

- Un **IDS** détecte des "motifs d'attaques" dans les trames réseaux et implémentés sous forme de signature. L'**IPS** est le pendant armé de l'IDS et va bloquer les IP qui ont levé une alerte.
- Ce type d'outil est moins efficace avec la généralisation du chiffrement mais est capable de donner des éléments sur les flux réseaux des attaquants. A ce titre il est toujours utile.
- Un **WAF** (**W**eb **A**pplication **F**irewall) est un IPS dédié aux applications web.



Outils IDP/IPS:

Snort!

C'est un IDS historique. A ce titre le format de ses règles est un standard y compris pour son concurrent Suricata. Racheté par Cisco, il a été ré-écrit (version 3) pour des raisons de performance (multi-threading et inspection http entre autre).



Outils IDP/IPS: Suricata

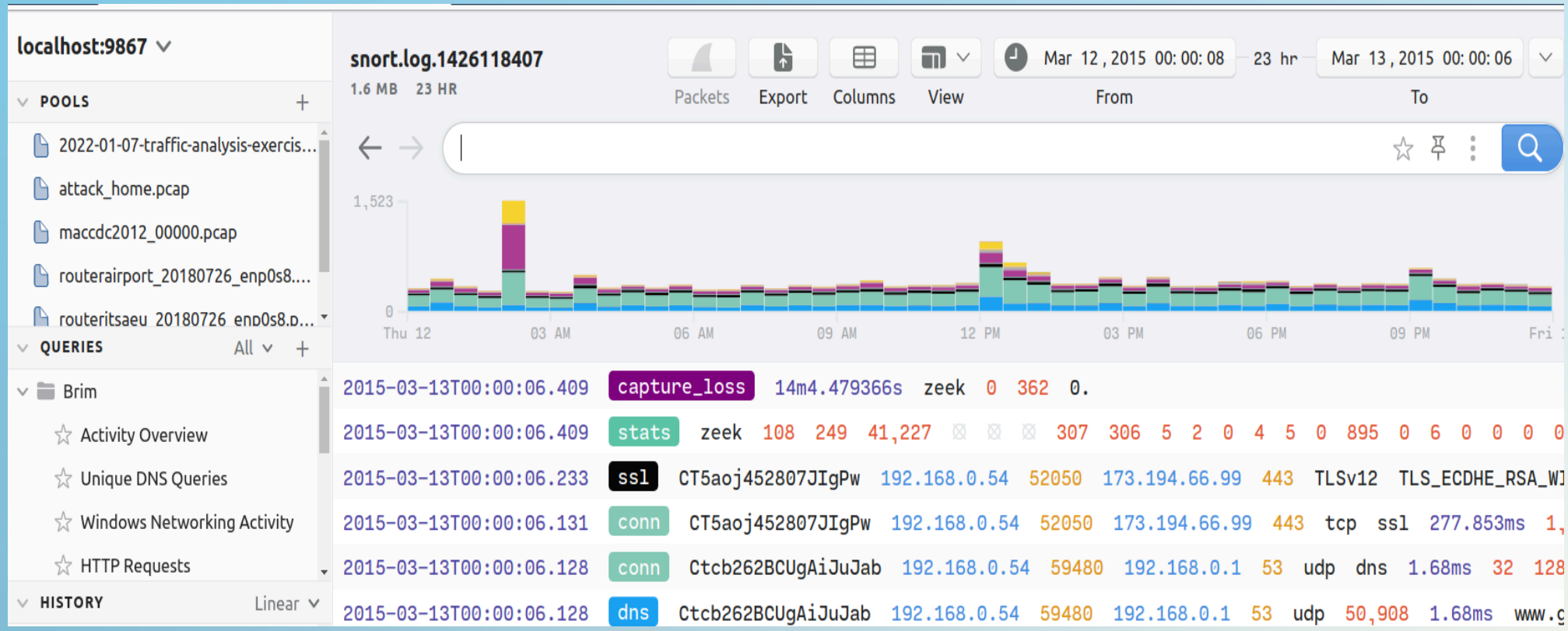
Plus récent (2009) que SNORT il a bénéficié d'une architecture modulaire et multi-threadé dès sa conception. C'est un outil intégré dans beaucoup d'autres du fait de son positionnement "opensource". Il ne sert pas qu'à la détection



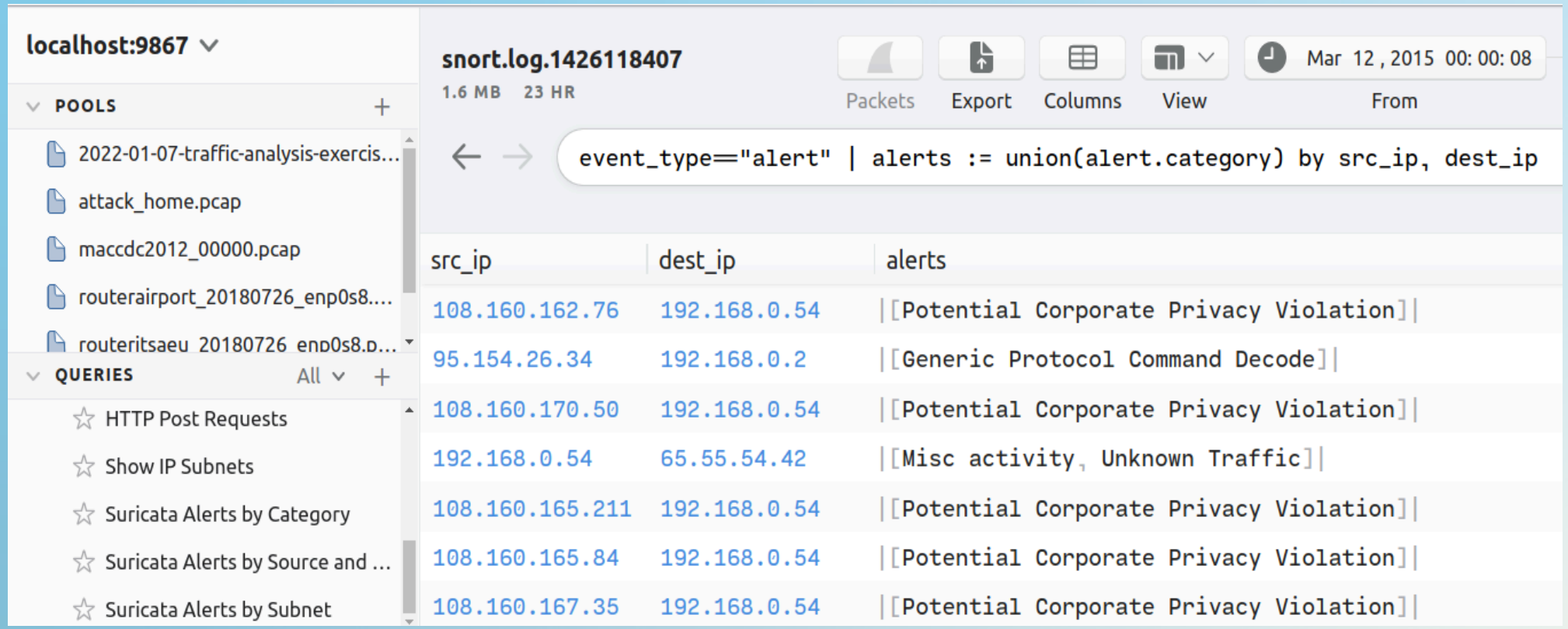
ZEEK est un analyseur comportemental du trafic

Zeek (ex Bro) est un peu à part des deux précédents IDS/IPS. Il est capable d'analyse protocolaire. Programmable (conception évènementielle), il est hautement adaptable. C'est le concurrent de Suricata.

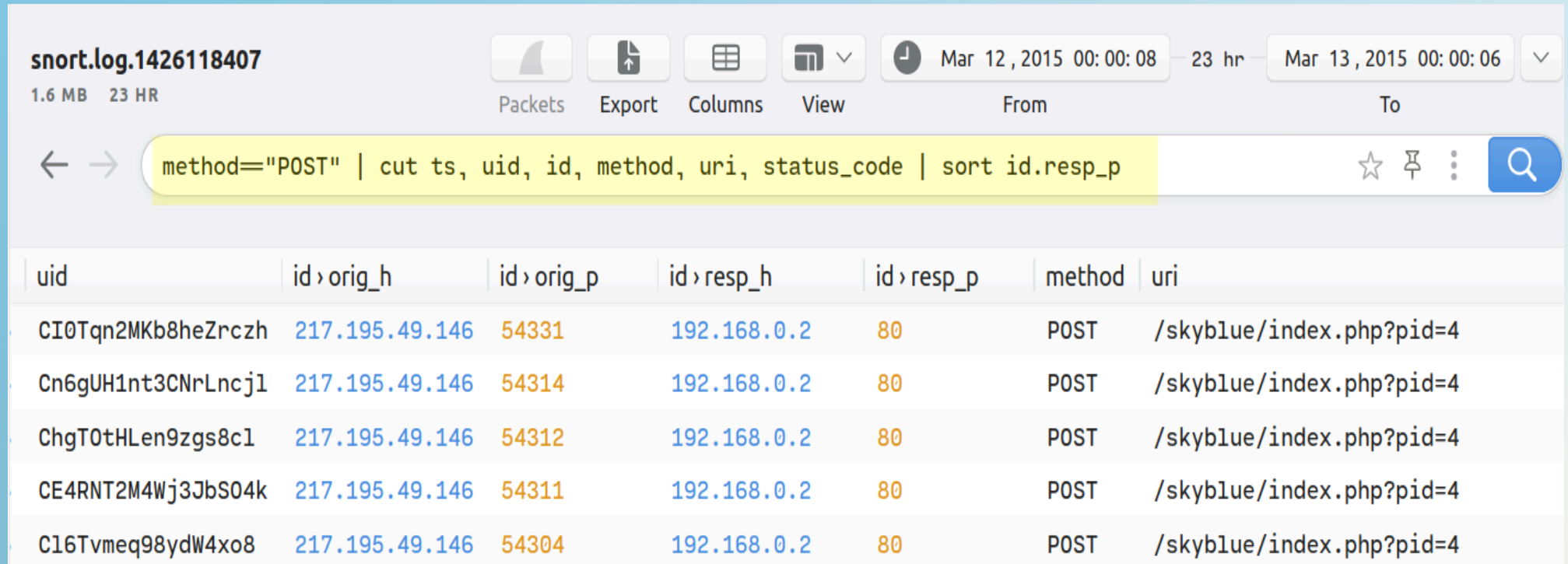
Zui ❤ est un client qui lit et "parse" rapidement de gros fichiers au format pcap



Zui embarque Suricata et affiche ses alertes



"Open Source", Zui s'appuie sur des données super-structurées formant un "data-lake", "parsable" avec un outil zq (modèle en "pipe" comme jq). Zed est un langage de requête qui permet de faire des recherches dans les données.



uid	id › orig_h	id › orig_p	id › resp_h	id › resp_p	method	uri
CI0Tqn2MKb8heZrczh	217.195.49.146	54331	192.168.0.2	80	POST	/skyblue/index.php?pid=4
Cn6gUH1nt3CNrLncjl	217.195.49.146	54314	192.168.0.2	80	POST	/skyblue/index.php?pid=4
ChgTOtHLen9zgs8cl	217.195.49.146	54312	192.168.0.2	80	POST	/skyblue/index.php?pid=4
CE4RNT2M4Wj3JbSO4k	217.195.49.146	54311	192.168.0.2	80	POST	/skyblue/index.php?pid=4
Cl6Tvmeq98ydW4xo8	217.195.49.146	54304	192.168.0.2	80	POST	/skyblue/index.php?pid=4

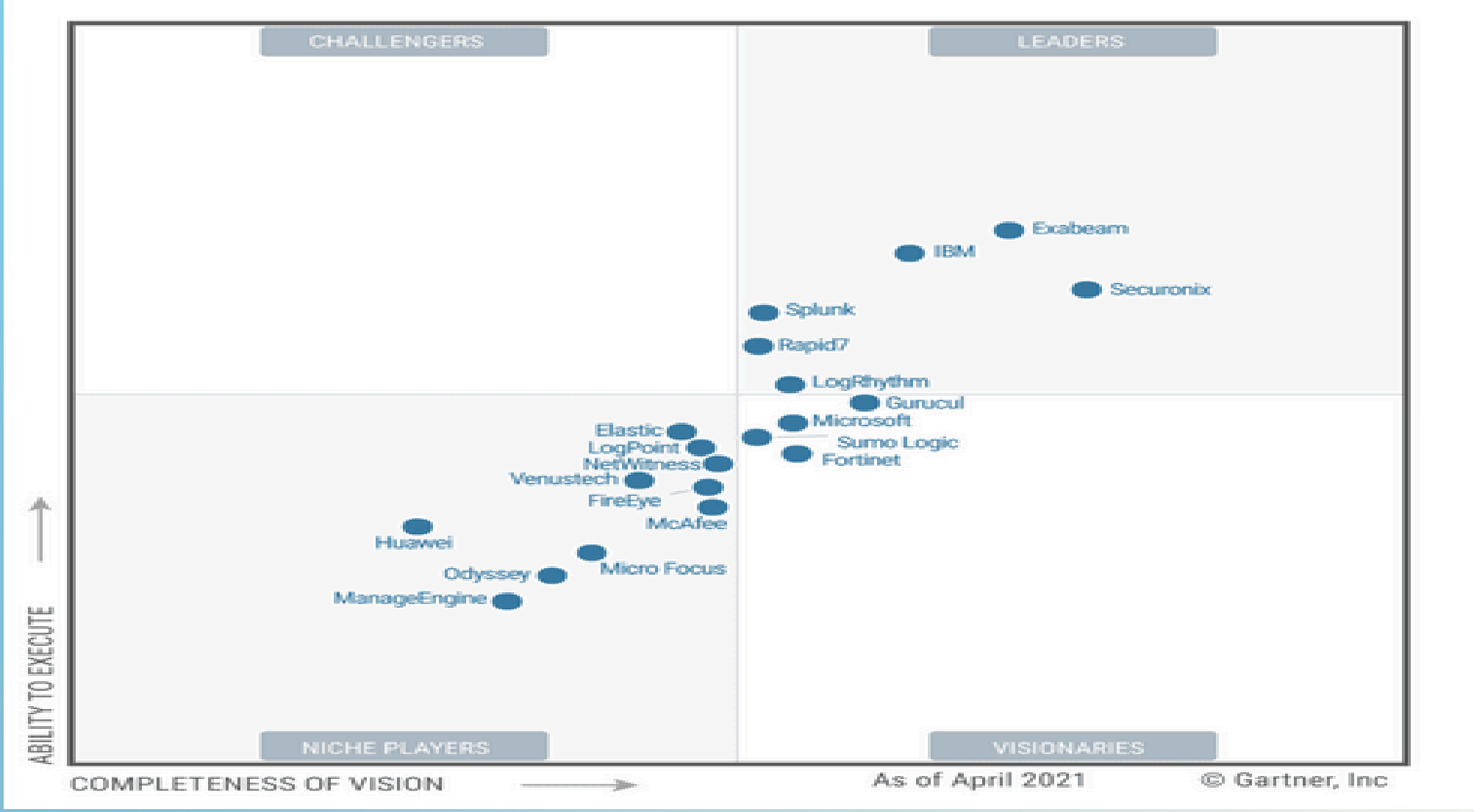
Origine et définition du SIEM.

- **SIEM** = **SIM** + **SEM**
- Le **SIM** (Security Information Management) correspond à la partie stockage et analyse des données. Il comprend la collecte , l'indexation, le Stockage et la recherche des données.
- Le **SEM** (Security Event Management) correspond à la partie détection (temps réel ou différé), la corrélation des évènements et le traitement d'incidents de sécurité.

Les SIEM (Security Information and Event Management)

- La détection et la neutralisation des menaces demandent de corréler les informations de multiples sources.
- C'est la promesse du **SIEM** qui est utile en particulier dans les S.O.C ("Security Operation Center").
- L'évolution des SIEM se fait comme dans d'autres secteurs de l'I.T. vers le **CLOUD** et l'**I.A.**.

La concurrence est rude sur ce segment



Les "10 commandements du SIEM"

(source podcast "no limit sécu" épisode 334 avec Etienne Ladent et Thomas Burnouf)

1. Des relais de collecte de logs **indépendants** tu mettras =>pour avoir un tampon de données avant le SIEM et éviter le D.O.S. involontaire , la perte, filtrer et diminuer les coûts de stockage.
2. Les "**regex**" tu apprendras" => pour retrouver efficacement des motifs. Un savoir-faire des analystes.
3. Le "**zéro alerte**" tu viseras => "Trop d'alertes tue l'alerte". Paradigme bien connu en supervision et ailleurs.

Les "10 commandements du SIEM"

4. Tes données d' **inventaire** tu collecteras => un analyste a besoin de ces données d'inventaire pour être efficace.
5. Sur tes **données utilisateurs** tu te formeras => Il faut comprendre les métiers).
6. Sur tes alertes tu **contextualiseras** => (Dans l'esprit d'EBIOS le métier oriente l'analyste et peut donner du sens à l'attaque).
7. Sur tes **recherches** tu refléchiras => les ressources sont limitées et un analyste ne doit pas les monopoliser.

Les "10 commandements du SIEM"

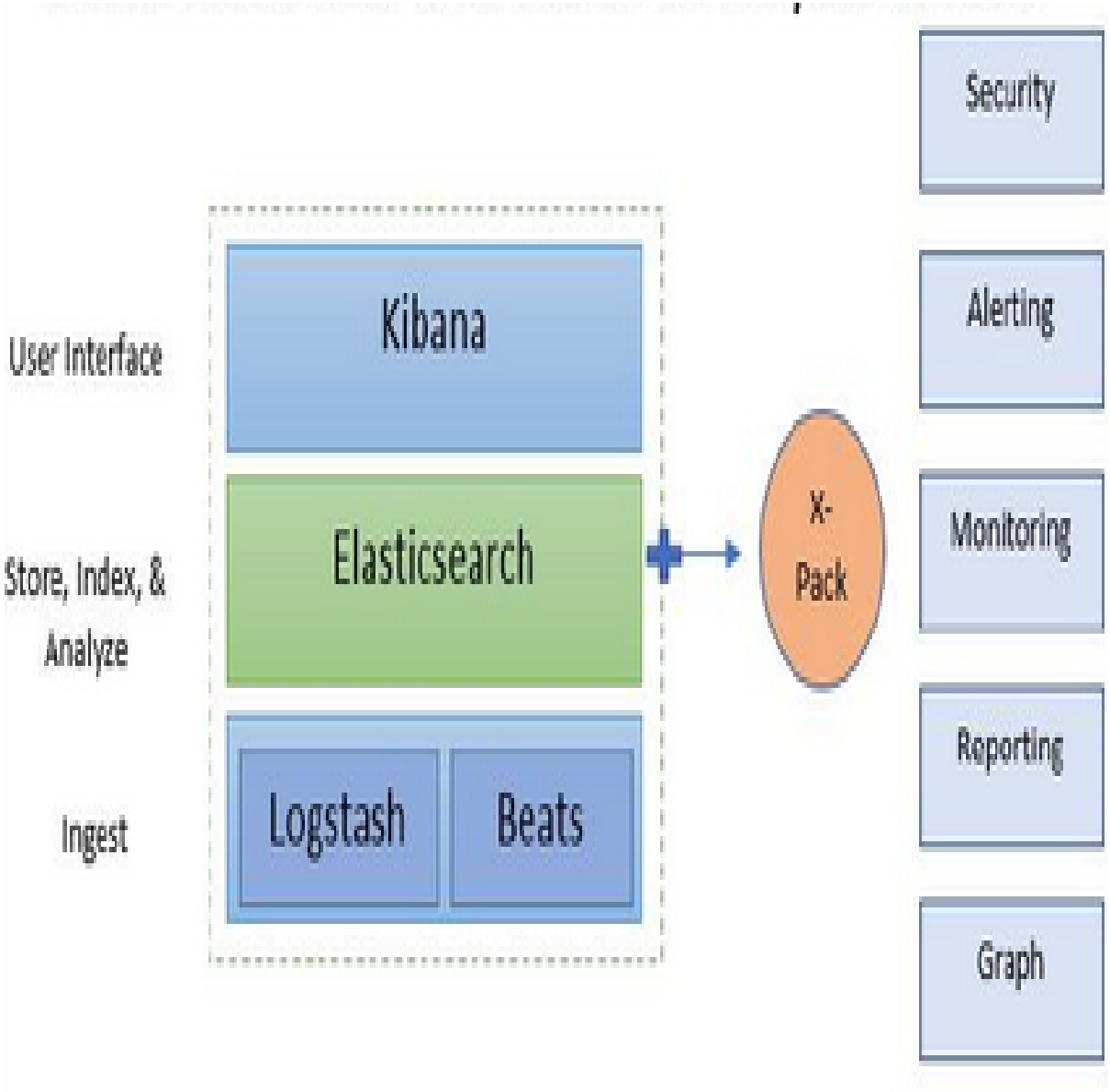
8. Tes alertes régulièrement tu contrôleras => **revue** des alertes suite à l'évolution du SI et des formats logs qui les rendent obsolètes == MCO
9. Tes données tu **documenteras** => évident.
10. Tes noms de données tu **nommeras**. (Un modèle de référence "Splunk Information Model") pour nommer de façon cohérente.

Wazuh & OSSEC

- **Wazuh** est un HIPS (**H**ost **I**ntrusion **P**rotection **S**ystem). Cette fonction est assurée par un agent qui détecte les anomalies/attaques/programmes malveillants/rootkit notamment à partir des fichiers de logs de la machine et l'écoute du réseau grâce à un "suricata" embarquée.
- **Wazuh** c'est aussi SIEM sur sa partie serveur qui agrège les logs des hôtes sous agent.
- **Wazuh** fait la correspondance entre les incidents de sécurité remontés par le agents et la matrice MITRE.

Wazuh & OSSEC

- **Wazuh** est capable de faire de la réponse à incident en mode automatique (SOAR) en déclenchant une action sur évènement: par exemple création d'une règle de firewall suite à un scan, une classification virale avec Yara suite à la création d'un fichier.
- **Wazuh** s'assure de la conformité réglementaire des machines hôtes sur plusieurs référentiels.(openscap et osquery pour l'inventaire)



Stack "Elastic"

- Elastic Search stocke les données sur un cluster de plusieurs noeuds
- La suite beats extrait des informations des fichiers de Log (Filebeat), du processus d'audit (Auditbeat), du traffic réseau (Packetbeat), ...

"Elastic Search"

- C'est un moteur de recherche et d'analyse , accessible en mode "RESTfull" et distribué.
- IL stocke des informations au format JSON.
- Il est performant pour des recherches textes et permet l'indexation de documents non structurées.
- Ses capacités permettent à son utilisateur de trouver des informations via Curl ou au travers de son API.

Logstash versus Beats

- C'est aussi un composant "Server Side" historique comme "Elastic Search". Écrit en JRuby (lent au démarrage et gourmand), il est important dans fonction ETL (transformation des données avec des regex standardisées).
- Les composants de Beats sont orientés "Client Side" et peuvent alimenter directement "Elastic Search". La "LibBeat" sert de base commune.

X-Pack

- Il ajoute les fonctions de sécurité, de monitoring , de supervision , de reporting et de "machine learning". Cette dernière fonction est payante et a pour but de détecter des comportements anormaux.

Elastic Agent & Fleet

Plutôt que de déployer chaque éléments de la suite beats, "Elastic Agent" s'installe sur les "endpoints" (les serveurs, les PC clients ...) et gère l'ensemble des "beats". Il est déployé via "Fleet" qui est un composant de "**Kibana**" (le front-end de la suite Elastic). **Fleet** permet de gérer les agents et de les déployer de façon centralisée.

"Endpoint Protection Platform" et les "Endpoint Detection and Response"

Ces composants permettent de combiner la protection du poste de travail avec la détection et la remédiation en cas d'alerte virale. Ils sont chargés de la protection des équipements terminaux (pc, smartphone ..):

- Les **EPP** sont des antivirus avec des fonctionnalités de prévention des menaces.
- Les **EDR** sont orientés sur le détection comportementale via l'**IA**, la surveillance de la mémoire et la présence d' "**I**ndicateurs de **C**ompromissions" (**IoC**).

"Dans la famille acronyme il y a" :

- SOC: "**S**ecurity **O**peration **C**enter.
- NDR: "**N**etwork **D**etection and **R**esponse.
- EDR: "**e**xtended **D**etection et **R**eponse".
- CIRT: "**C**omputer **S**ecurity **I**ncident **R**esponse **T**eam.
- SOAR: "**S**ecurity **O**rchestration **A**utomation and **R**esponse".
- MDR: "**M**anagement **D**etection and **R**esponse".

Si vous voulez être incompris par les "moldus"

- Le **NDR** est le processus de haut niveau qui apporte une visibilité à l'échelle du réseau aux équipes **CSIRT** du **SOC** afin de détecter les comportements malveillants au niveau des infrastructures. Il ne s'occupe donc pas des points terminaux dévolus aux **EPP**/**EDR**.
- Le **XDR** réunit **NDR** et **EPP**. L'information est correlée au niveau de l'entreprise, il s'agit de centraliser.
- Le **MDR** regroupe les solutions managées qui permettent d'automatiser et de fluidifier au travers du **SOAR** (réponse aux incidents).

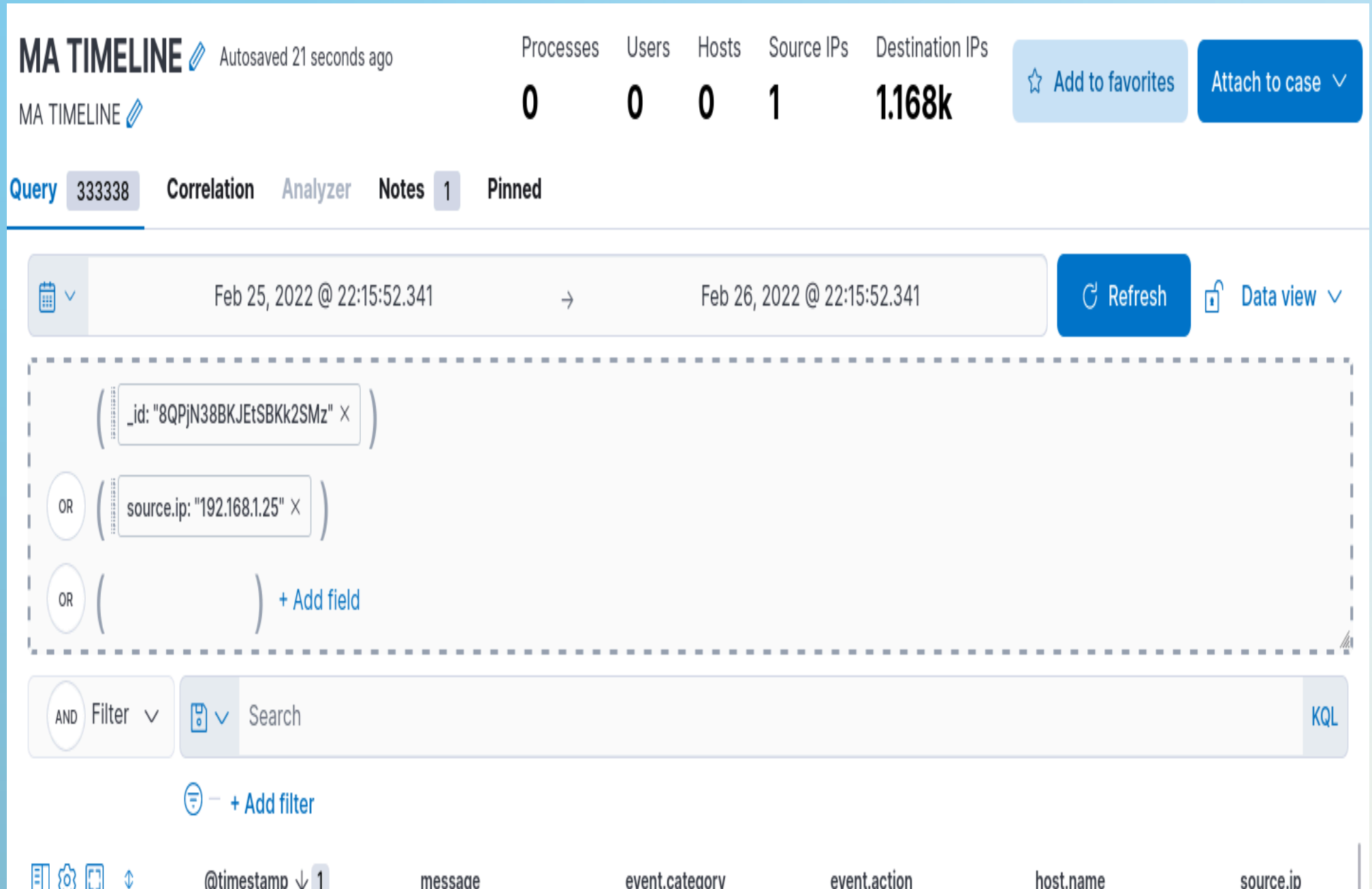
Fonctions des EDR

- Enregistrer les comportements des systèmes sur une granularité "endpoints" ou des "hôtes".
- Détecter des comportements anormaux.
- Fournir de l'information contextuelle.
- Bloquer les activités malveillantes.
- Permettre la remédiation.

Elastic Security

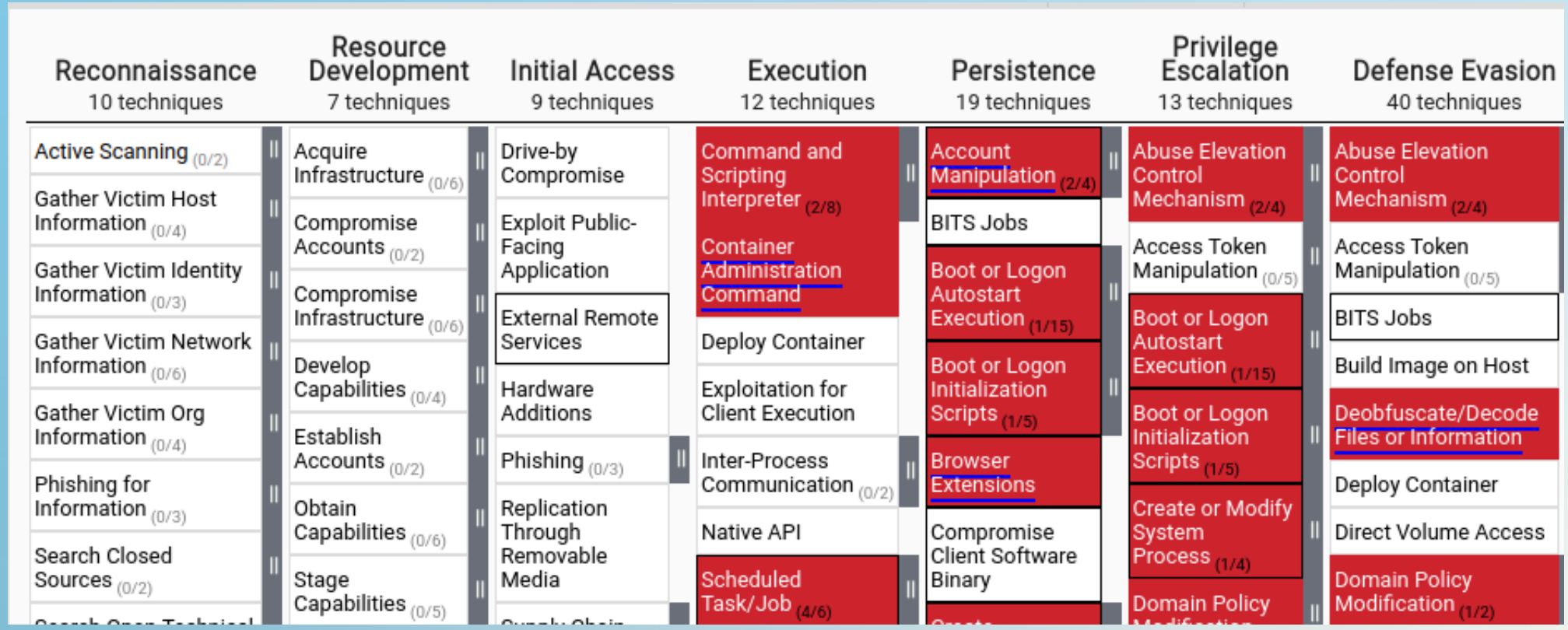
Kibana est le front end de la suite Elastic et permet de déployer des tableaux de bord. Certains sont orientés sécurité et constituent un SIEM: "**Elastic Security**"

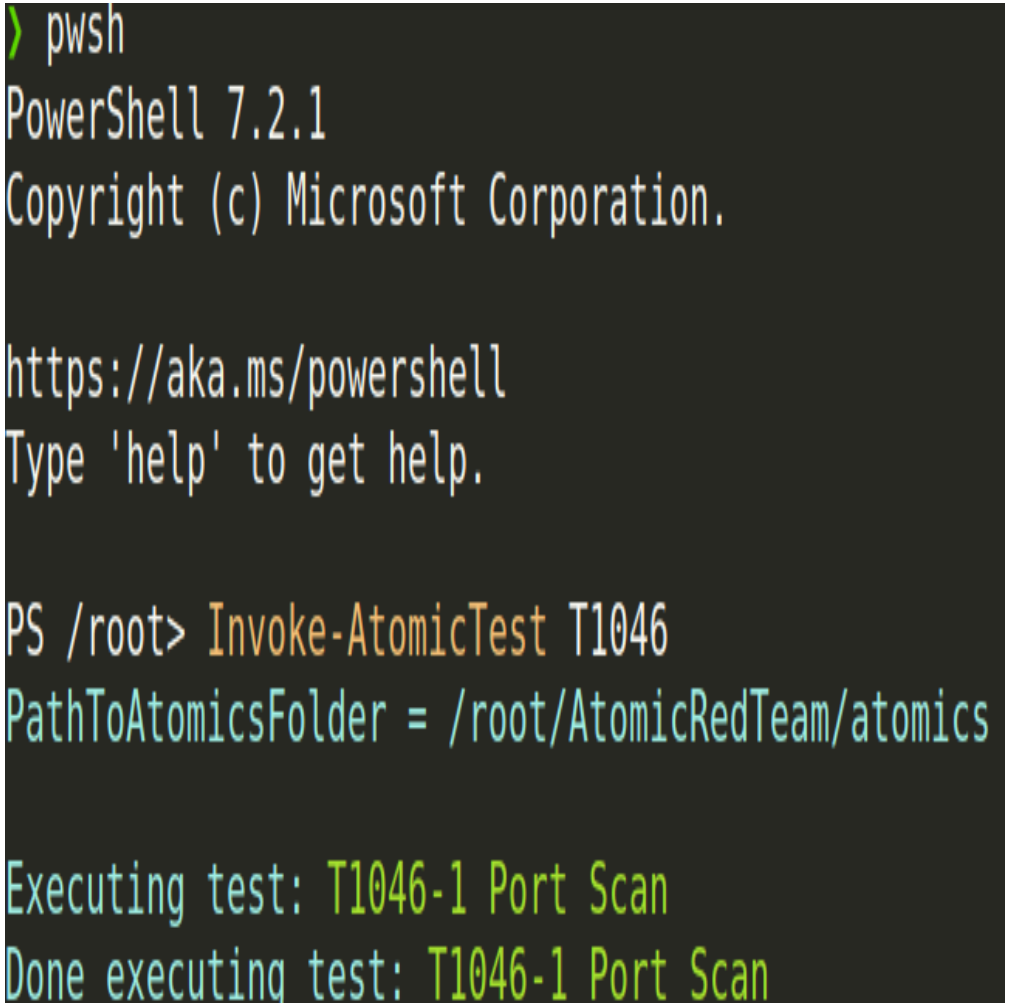
La corrélation est possible par adjonction d'une **TimeLine**. Il est possible d'ouvrir et de suivre des incidents de sécurité au travers de "Case".


MA TIMELINE
Autosaved 21 seconds ago
MA TIMELINE
Processes
0
Users
0
Hosts
0
Source IPs
1
Destination IPs
1.168k
Add to favorites
Attach to case
Query 333338
Correlation
Analyzer
Notes 1
Pinned
Feb 25, 2022 @ 22:15:52.341
Feb 26, 2022 @ 22:15:52.341
Refresh
Data view
_id: "8QPjN38BKJEtSBKk2SMz"
OR
source.ip: "192.168.1.25"
OR
+ Add field
AND
Filter
Search
KQL
+ Add filter
@timestamp
message
event.category
event.action
host.name
source.ip

Comment tester son SIEM ?

En se basant sur le framework Mitre des techniques d'attaques observées.





- On utilise des outils comme ceux d' **Atomic RedTeam** qui vont tester les défenses d'un hôte afin d'en vérifier la conformité.
- On peut aussi rejouer des pcaps qui contiennent des traces des tentatives d'intrusion.

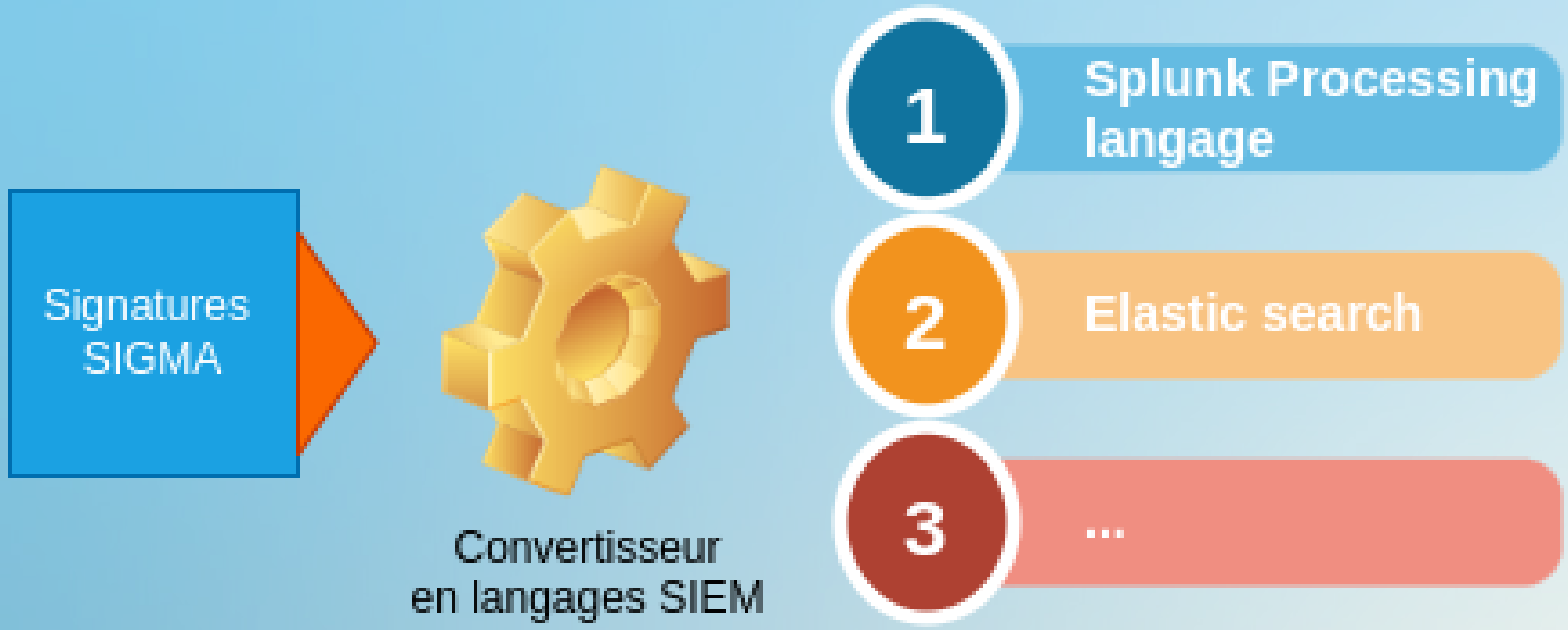
"Un Anneau pour les gouverner tous..."

- Chaque SIEM a son propre langage de requête avec des champs proches mais pas identiques (*ip_addr, IPAddres*...).
- Développer des requêtes prend du temps et échapper au "*vendor lock-in*" est difficile.

Les règles Sigma

- L'idée des "**SIGMA rules**" est de proposer un langage commun pour les requêtes de détection d'attaques. C'est un format générique décrivant les règles. C'est l' équivalent des règles Suricata pour les IDS/IPS et de "Yara" pour la détection de malwares.
- On a donc un format décrivant les règles de détection et un convertisseur qui permet de générer des règles adaptées à chaque SIEM (plus de vingt dont des solutions proches des endpoints comme **Chainsaw** et **Hayabusa**...).

"Un anneau pour les gouverner tous...".



Les en-têtes d'une règle sigma

```
title: Mimikatz Use
id: 06d71506-7beb-4f22-8888-e2e5e2ca7fd8
status: test
description: This method detects mimikatz keywords
in different Eventlogs (some of them only appear
in older Mimikatz version that are however still used by different threat groups)
references:
    - https://tools.thehacker.recipes/mimikatz/modules
author: Florian Roth (Nextron Systems), David ANDRE (additional keywords)
date: 2017/01/10
modified: 2022/01/05
tags:
    - attack.s0002
    - attack.lateral_movement
    - attack.credential_access
    - car.2013-07-001
    - car.2019-04-004
    - attack.t1003.002
    - attack.t1003.004
    - attack.t1003.001
    - attack.t1003.006
```

Le corps d'une règle sigma

```
logsource:
    product: windows
detection:
    keywords:
        - 'dpapi::masterkey'
        - 'eo.oe.kiwi'
        - 'event::clear'
        - 'event::drop'
        - 'gentilkiwi.com'
        - 'kerberos::golden'
        ...
        - 'sekurlsa::'
    filter:
        EventID: 15  # Sysmon's FileStream Events
        (could cause false positives when Sigma rules get copied on/to a system)
    condition: keywords and not filter
falsepositives:
    - Naughty administrators
    - AV Signature updates
    - Files with Mimikatz in their filename
level: high
```

Les siem cibles de sigma

```
sigma list targets
+---------------+-------------------------------------+-----------------------------+
| Identifier    | Target Query Language               | Processing Pipeline Required |
+---------------+-------------------------------------+-----------------------------+
| elasticsearch | Elasticsearch Lucene                | Yes                          |
| opensearch    | OpenSearch Lucene                   | Yes                          |
| splunk        | Splunk SPL & tstats data model queries | Yes                       |
+---------------+-------------------------------------+-----------------------------+
```

Conversion d'une règle sigma en requête SIEM

```
sigma convert -t opensearch  -f default  -p sysmon  win_alert_mimikatz_keywords.yml
Parsing Sigma rules  [####################################]  100%
("dpapi\:\:masterkey"
OR "eo.oe.kiwi"
OR "event\:\:clear"
OR "event\:\:drop"
OR "gentilkiwi.com"
OR "kerberos\:\:golden"
OR "kerberos\:\:ptc"
...

OR "privilege\:\:debug"
OR "privilege\:\:driver" OR "sekurlsa\:\:")
AND (NOT EventID:15)
```

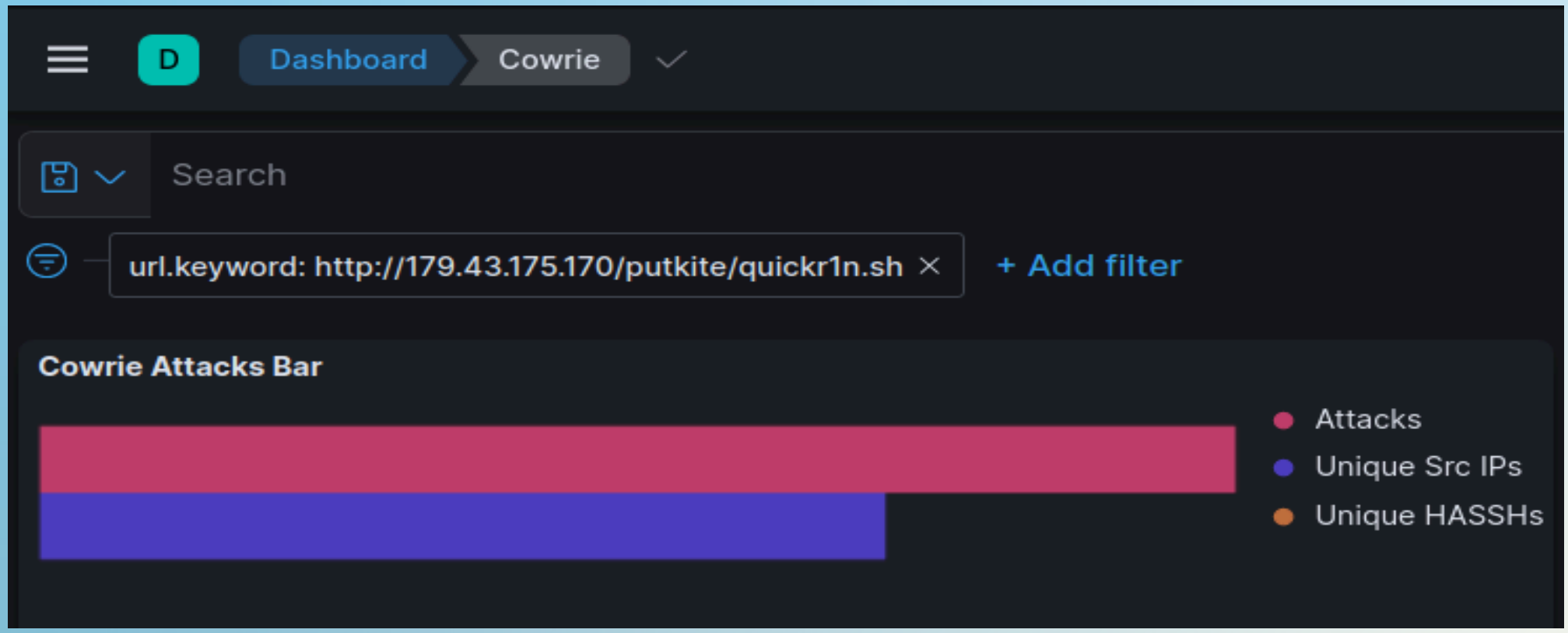
Génération en language SIEM via sigmac (déprécié)

```
sigmac -t splunk -c splunk-dns
./net_dns_external_service_interaction_domains.yml
#Résultat en SPL
(query="*.interact.sh*"
OR query="*.oast.pro*"
OR query="*.oast.live*"
OR query="*.oast.site*"
OR query="*.oast.online*"
OR query="*.oast.fun*"
OR query="*.oast.me*"
OR query="*.burpcollaborator.net*"
OR query="*.oastify.com*"
OR query="*.canarytokens.com*"
OR query="*.requestbin.net*"
OR query="*.dnslog.cn*")
```

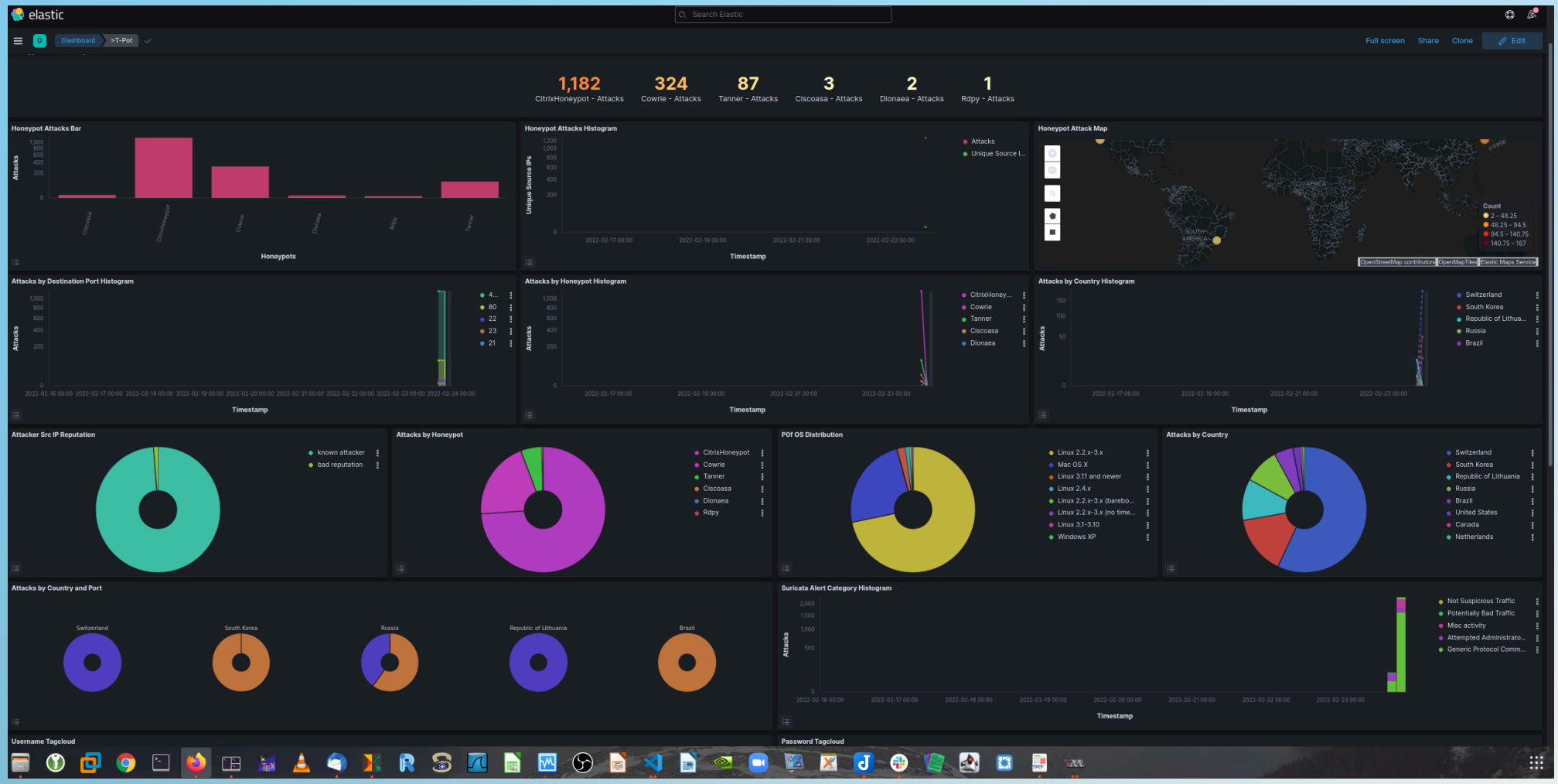
HoneyPot qui mal y pense...

- Une façon de détecter les intrusions réseaux et d'analyser les évolutions des attaques c'est de mettre en place un **Honeypot**.
- Les honeypots à faible interaction offrent de faux services et n'offrent que peu de privilèges à l'attaquant. L'**interaction** avec l'attaquant est faible. Simple à mettre en oeuvre ils sont limités et recueillent les attaques automatisées et sans intelligence.
- Au contraire les honeypots à forte interaction permettent à l'attaquant d'aller loin dans son parcours, avec à la clef une analyse en profondeur du mode d'attaque mais ils demandent plus d'attention et de ressources.

TPOT combine de nombreux honeypots implémentés sous forme de containers Docker. Il donne des renseignements comme ici une URI de téléchargement d'un logiciel malveillant:



R5.cyber.11 Supervision de la sécurité: les outils de détection



Bibliographie:

- PDIS ANSSI
- Hands-On Network Forensic - auteur Nipun Jaswal- Packt
- Learning Elastic Stack 7.0 - Second Edition Shukla, Pranav Kumar M N, Sharath Packt
- Introduction to Network Forensics FINAL VERSION 1.1 ENISA
- Définitions soc-siem-xdr-mdr par Orange Cyberdéfense
- SOC - Stratégie de détection par Maurugeon Cédric Menelet Alain Misc 120

...